Informe de Incidente de Seguridad de la Información

Anexo D — Caso Práctico C05: PagoClaro Fintech S.A.S.

1. Identificación del Incidente

N.º de Incidente: INC-2026-1018-007

Ticket GLPI: ID #7

Fecha y Hora: 2026-10-18

Analista SOC N1: JonathanQuintero-WendyJaimes

Severidad Final: Alta (High)

Estado Actual: En Contención (Pending)

2. Resumen Ejecutivo

El 18 de octubre de 2026 se detectó un correo electrónico malicioso dirigido al área de contabilidad que contenía un archivo adjunto con código dañino. El sistema de protección en el equipo (Kaspersky EDR) interceptó la ejecución del archivo y aisló preventivamente la estación de trabajo. Actualmente la amenaza fue neutralizada, el equipo se encuentra en revisión técnica y no se evidenció fuga ni compromiso de información transaccional.

3. Detección

La amenaza fue identificada primariamente por el agente Kaspersky Endpoint Security Cloud (EDR/XDR) e integrada en tiempo real mediante formato CEF/Syslog hacia el servidor Wazuh SIEM (regla de correlación 100201). Complementariamente, el usuario afectado generó el reporte inicial a través de la mesa de ayuda GLPI Cloud (Ticket ID #7) a las 11:58:00 horas.

4. Línea de Tiempo del Incidente

Hora (UTC-5)	Evento Registrado	Fuente / Componente
11:58:00	Recepción de correo sospechoso con ejecutable y reporte del usuario en GLPI.	Usuario / GLPI Cloud
11:58:15	Intento de ejecución interceptado y neutralizado por la protección EDR.	Kaspersky EDR
11:58:17	Reenvío de traza CEF vía Syslog hacia el colector central de eventos.	Syslog / Wazuh Agent
11:58:19	Disparo de alerta personalizada nivel 10 (MITRE ATT&CK T1204) en el SIEM.	Wazuh SIEM Manager
12:03:00	Asignación del ticket de soporte al analista SOC N1 para procedimiento de triage.	Mesa de Ayuda GLPI
12:15:00	Aislamiento lógico de red aplicado a la estación de trabajo desde la consola central.	Consola Kaspersky EDR

5. Activos y Usuarios Afectados

La afectación se limitó de forma contenerizada al segmento administrativo de la organización:

- **Equipo / Host:** FIN-WIN11-04 (Estación de Trabajo de Contabilidad)
- **Dirección IP Asignada:** 192.168.10.105
- **Usuario Involucrado:** jquintero (Área de Contabilidad)
- **Servicios Afectados:** Módulo local de cuentas por pagar y correo electrónico corporativo. No existió compromiso sobre la base de datos de tarjetahabientes ni el core transaccional.

6. Análisis Técnico de la Amenaza

Se realizó la extracción y análisis de la trama CEF en el servidor Wazuh SIEM:

```
CEF:0|KasperskyLab|KESCloud|12.3.0|1001|Malware Detected|8|src=192.168.10.105 suser=jquintero host=FIN-WIN11-04 msg=Phishing_Payload act=Quarantined
```

Causa Probable: Ataque de Phishing dirigido (*spear-phishing*) con suplantación de identidad de un proveedor de facturación electrónica.

Indicadores de Compromiso (IoCs):

- **Nombre del Archivo:** Factura_Pendiente_PagoClaro.exe
- **Hash SHA-256:** 275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f
- **IP Externa / C2:** 198.51.100.45

7. Contención y Respuesta

1. **Aislamiento de Red (12:15 PM):** Activación de regla de aislamiento en Kaspersky EDR para cortar la comunicación de FIN-WIN11-04 con el segmento de red interna, manteniendo tráfico exclusivo hacia el SIEM.
2. **Cuarentena (12:25 PM):** Eliminación y puesta en cuarentena del artefacto ejecutable mediante políticas centralizadas.
3. **Bloqueo Perimetral (12:40 PM):** Inclusión de la IP y dominio emisor en la lista de rechazo del firewall perimetral y pasarela de correo.

8. Evaluación del Impacto

Dimensión	Nivel	Justificación Técnica
Confidencialidad	Nulo	No hubo exfiltración de datos sensibles ni accesos no autorizados a bases de datos.
Integridad	Nulo	No se registraron modificaciones no autorizadas en

9. Plan de Recomendaciones

N.º	Acción Correctiva / Preventiva	Responsable	Fecha Límite
1	Ejecutar escaneo completo de vulnerabilidades (SCA) antes de autorizar la reconexión.	Analista N1 / Soporte	2026-10-19
2	Ajustar políticas de filtrado en el Gateway de correo para ejecutables comprimidos.	Administración N2	2026-10-21
3	Realizar jornada de concientización sobre Phishing e Ingeniería Social al personal.	Oficial de Seguridad	2026-10-25

10. Lecciones Aprendidas

Aspectos Positivos: La integración mediante Syslog/CEF entre Kaspersky EDR y Wazuh SIEM garantizó un tiempo de respuesta inferior a 2 segundos desde la detección hasta la generación de la alerta en el Dashboard.

Oportunidades de Mejora: El correo malicioso logró eludir la primera capa de inspección antispam. Se requiere fortalecer los filtros de reputación de dominio en la entrada de correo.

Ajustes de Procesos: Se iniciará la automatización (SOAR) para que alertas críticas de Kaspersky generen automáticamente el ticket de incidente en GLPI Cloud mediante API Webhook.

11. Notificaciones Escaladas

Se notificó formalmente al CISO y al responsable del SOC a las 12:10 PM vía GLPI Cloud y correo interno. No se requirió notificación externa a la Superintendencia de Industria y Comercio (SIC) ni al ColCERT al no registrarse afectación a infraestructuras críticas ni fuga de datos personales (Ley 1273 de 2009 / Ley 1581 de 2012).

12. Anexos

- **Anexo 12.1:** Registro de captura de pantalla de la consola Kaspersky EDR con la acción *Quarantined*.
- **Anexo 12.2:** Extracto de logs en formato JSON almacenados en `/var/ossec/logs/alerts/alerts.json`.
- **Anexo 12.3:** Ficha de exportación en PDF del Ticket GLPI ID #7.